Active Directory Attack and Detection Lab

JULY 2026 · Anele

1. Overview

This project is a blue team home lab built around a Windows Server 2022 domain controller. From a Kali Linux attacker machine I simulated a realistic domain compromise, then traced each step in the Windows Security log to see what defenders can observe and how to alert on it. The attack chain covers enumeration, password spraying, and account creation with escalation to Domain Admin. The detection work extends this with custom Splunk rules and a Python SOC automation pipeline.

All activity was performed in a virtual lab on systems I own. Credentials visible in the evidence screenshots are redacted.

2. Objectives

- Build an Active Directory environment that produces realistic attack telemetry
- Simulate common identity-based attacks from an external attacker host
- Identify the Windows Event IDs each technique generates
- Turn those events into detection logic and map them to MITRE ATT&CK
- Document findings and hardening steps in a portfolio-ready format

3. Lab architecture

Role	System	Details
Attacker	Kali Linux, `192.168.10.30`	NetExec for enumeration and spraying
Domain controller	`DC01`, `192.168.10.10`	Windows Server 2022 (Build 20348), domain `corp.local`, SMB signing on, SMBv1 off, LDAP signing not enforced
Client	`CLIENT01`	Domain-joined workstation, visible as a computer object in LDAP
Hypervisor	Oracle VirtualBox	Lab network `192.168.10.x`

Directory objects: users `Administrator`, `Guest`, `krbtgt`, `john.smith`, `sarah.jones`, `mike.brown`; custom groups `IT Admins`, `HR Users`, `Finance Users`.

Phase 1: Enumeration

I enumerated `DC01` over SMB and LDAP with NetExec, authenticating as the built-in `Administrator` account (password redacted). NetExec returned `Pwn3d!`, confirming administrative access.

```
netexec smb  192.168.10.10 -u Administrator -p '<REDACTED>' --users
netexec smb  192.168.10.10 -u Administrator -p '<REDACTED>' --shares
```

```
netexec ldap 192.168.10.10 -u Administrator -p '<REDACTED>' --groups
netexec ldap 192.168.10.10 -u Administrator -p '<REDACTED>' --computers
```

Results

- **Users:** 6 accounts returned with password-last-set times, including the `krbtgt` service account.
- **Shares:** `ADMIN$`, `C$`, `NETLOGON`, and `SYSVOL` were readable and writable; `IPC$` was read-only.
- **Groups:** built-in groups plus `IT Admins`, `HR Users`, and `Finance Users`; `Administrators` had 3 members. NetExec does not support `--groups` over SMB and redirects to LDAP.
- **Computers:** 2 records, `DC01$` and `CLIENT01$`.

Observation: the LDAP banner reported `signing:None` and `channel binding: No TLS cert`, so LDAP signing and channel binding were not enforced on the domain controller.



Figure 1: Domain users returned by NetExec over SMB.

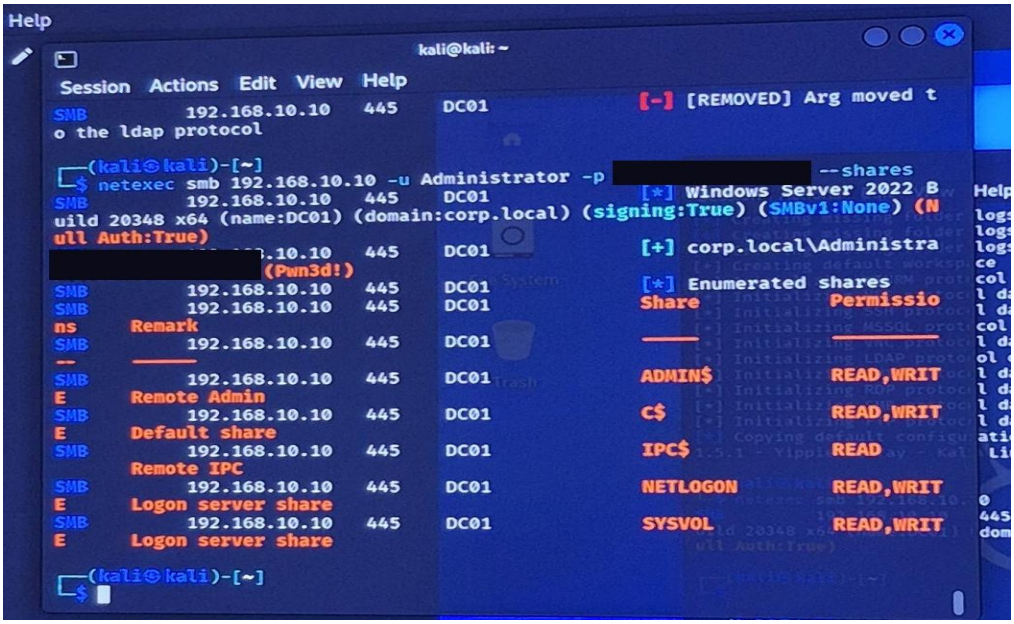


Figure 2: Shares enumerated on `DC01` with their permissions.

Phase 2: Password spraying and detection

On 2026-07-30 I tried a single password against a username list, the classic spraying pattern that avoids locking accounts.

```
netexec smb 192.168.10.10 -u users.txt -p "Password123"
```

All three attempts returned `STATUS_LOGON_FAILURE`.

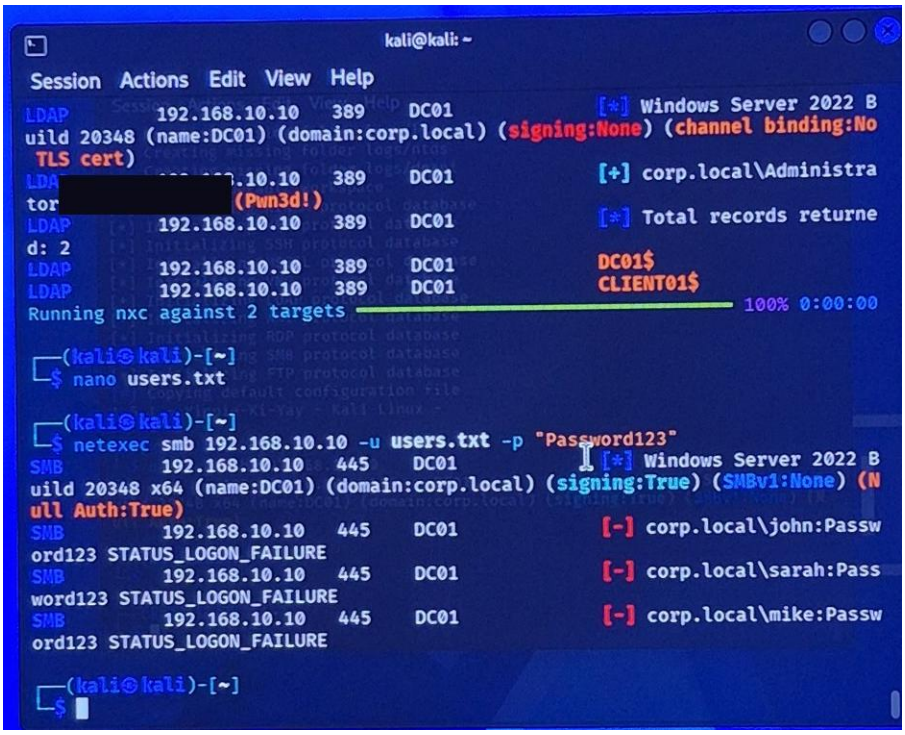


Figure 3: The spray from Kali and its three failed logons.

Detection: Event ID 4625. Filtering the Security log on `DC01` to 4625 showed three failures in the same second (13:13:09). The event details identify the source and target:

- Source network address `192.168.10.30` (the Kali host), source port `47852`
- Logon process `NtLmSsp`
- Account name `sarah`, domain `corp.local`

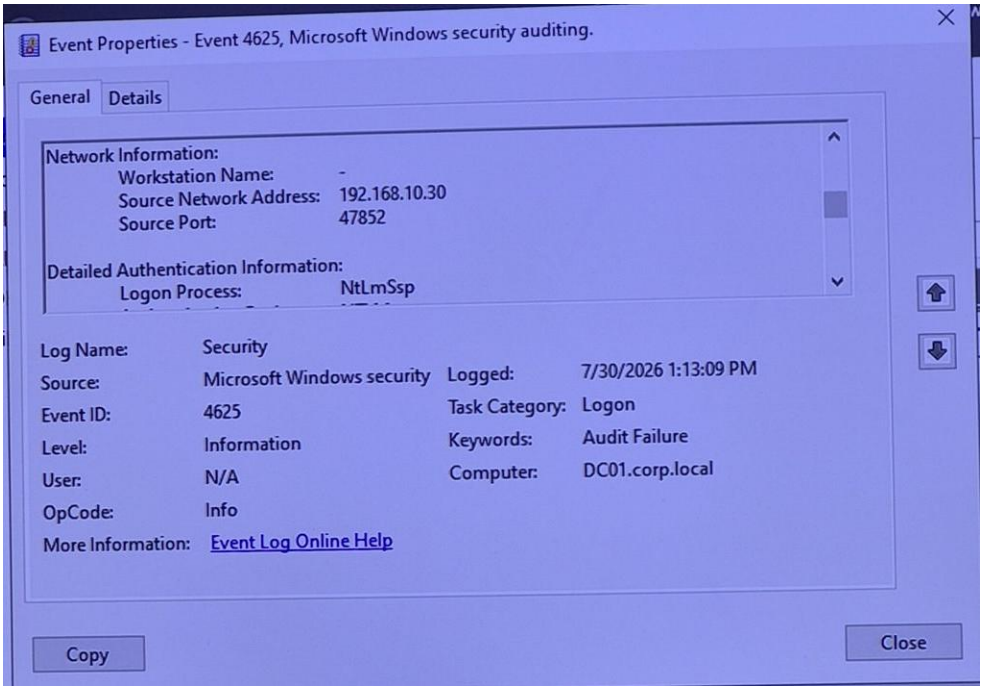


Figure 4: Event 4625 details showing the attacker IP and logon process.

Phase 3: Account creation and privilege escalation

On 2026-08-01, using the `Administrator` session, a new domain account was created and added to `Domain Admins`. Each step is recorded on `DC01`:

Time	Event ID	What it shows
16:34:08	4624	Network logon (Type 3) with an elevated token
16:52:34	4720	`CORP\Administrator` (Logon ID `0x3F604`) created `CORP\test.user`
16:54:56	4728	The same Logon ID added `CN=Test User,OU=Employees,DC=corp,DC=local` to `CORP\Domain Admins`
16:56:08	4672	Special privileges assigned, including `SeDebugPrivilege`, `SeBackupPrivilege`, `SeRestorePrivilege`, `SeTakeOwnershipPrivilege`, and `SeLoadDriverPrivilege`

Because the 4720 and 4728 events share one Logon ID, account creation and escalation can be correlated into a single alert.

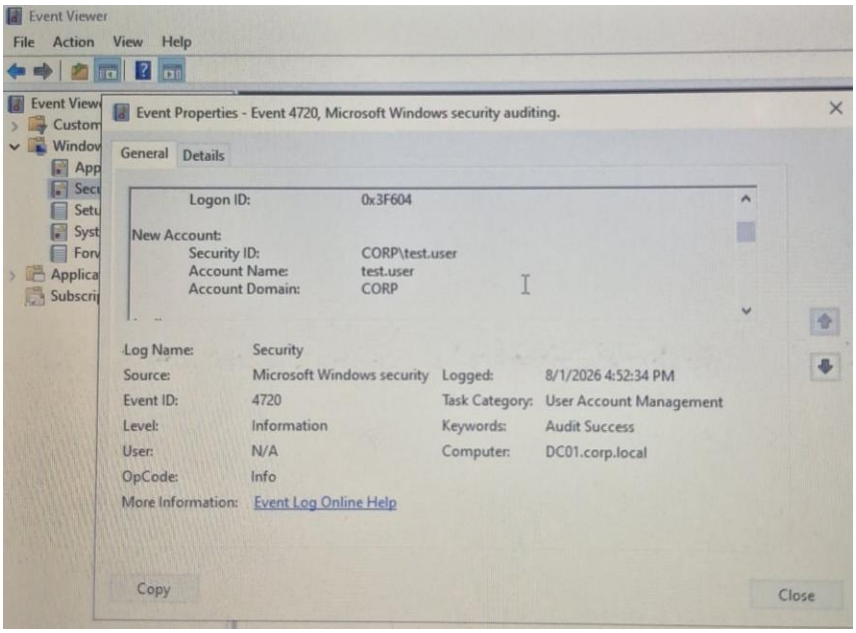


Figure 5: Event 4720, user account `test.user` created.

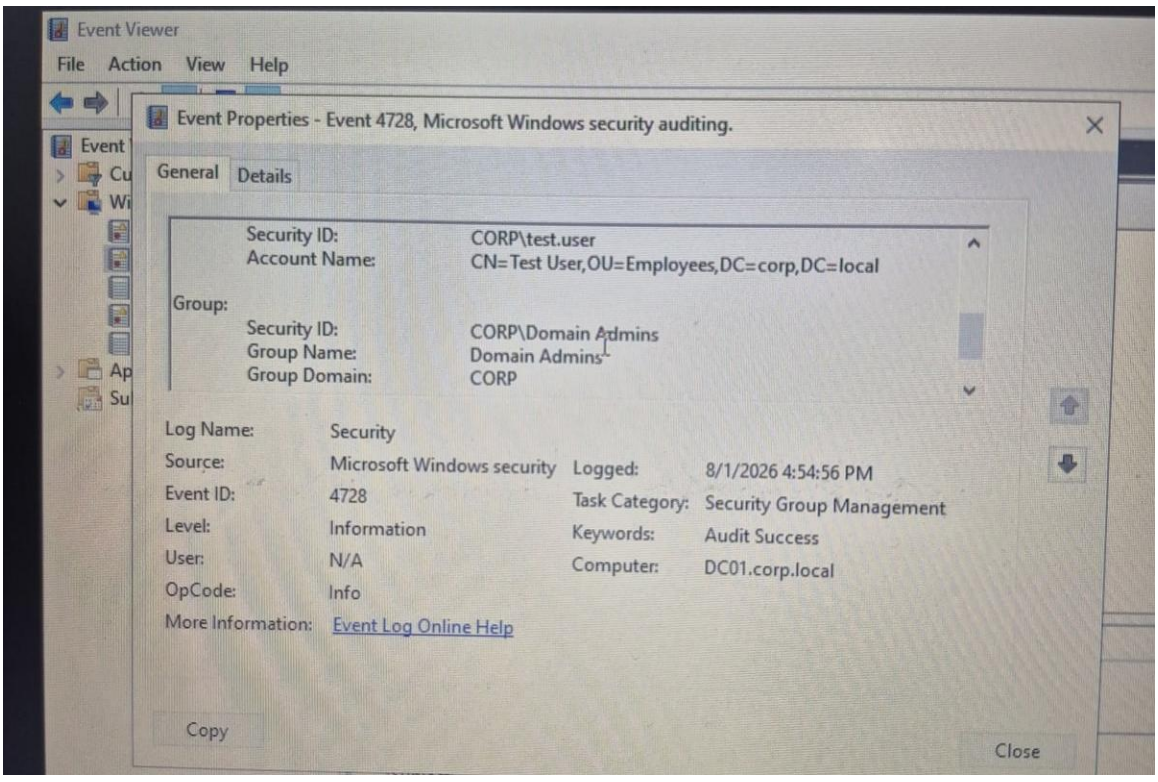


Figure 6: Event 4728, member added to Domain Admins.

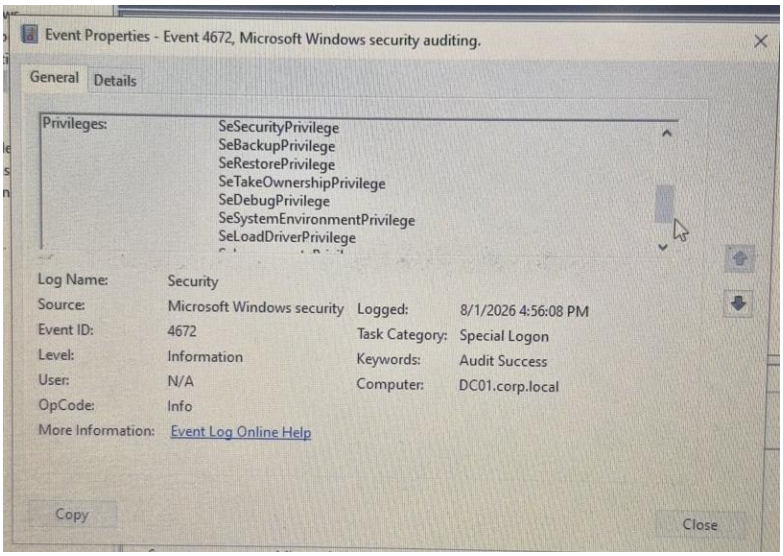


Figure 7: Event 4672, sensitive privileges assigned to a new logon.

Findings and hardening

- LDAP signing and channel binding were not enforced. Enable LDAP signing and channel binding to help prevent NTLM relay attacks.
- The built-in Administrator account permitted remote SMB and LDAP enumeration. Restrict remote access, implement tiered administrative accounts, and enforce strong, unique passwords.
- Password spray detection relied on Event ID 4625 volume. Implement account lockout policies alongside threshold-based alerts to improve detection and reduce brute-force attempts.
- Changes to the Domain Admins group required real-time monitoring. Event ID 4728 provided the clearest indication of privilege escalation and should trigger immediate security alerts.

MITRE ATT&CK mapping

Technique	ID
Brute Force: Password Spraying	T1110.003
Valid Accounts: Domain Accounts	T1078.002
Create Account: Domain Account	T1136.002
Account Manipulation	T1098

Skills demonstrated

- Active Directory enumeration and attack simulation (NetExec, SMB, LDAP, NTLM)

- Windows Security log analysis and Event ID interpretation
- Detection engineering with Splunk SPL and MITRE ATT&CK mapping
- Python automation for SOC workflows (Flask, Slack integration)
- Technical documentation for GitHub and portfolio use

Appendix: Windows Event ID reference

Event ID	Meaning	Seen in this lab
4625	An account failed to log on	Password spray
4624	An account was successfully logged on	Network logon before escalation
4720	A user account was created	`test.user` created
4728	A member was added to a security-enabled global group	`test.user` added to Domain Admins
4672	Special privileges assigned to new logon	Sensitive privileges on `DC01`